Universiti Tun Hussein Onn Malaysia

UNIVERSITI TUN HUSSEIN ONN MALAYSIA

FINAL EXAMINATION
SEMESTER I
SESSION 2022/2023

COURSE NAME	:	SOFTWARE SECURITY
COURSE CODE	:	BIS 20503
PROGRAMME CODE	:	BIS
EXAMINATION DATE	:	FEBRUARY 2023
DURATION	:	3 HOURS
INSTRUCTION	:	1. ANSWER **ALL** QUESTIONS.
		2. THIS FINAL EXAMINATION IS CONDUCTED VIA **CLOSED BOOK**.
		3. STUDENTS ARE **PROHIBITED** TO CONSULT THEIR OWN MATERIAL OR ANY EXTERNAL RESOURCES DURING THE EXAMINATION CONDUCTED VIA CLOSED BOOK.

THIS QUESTION PAPER CONSISTS OF **EIGHT (8)** PAGES

TERBUKA

SECTION A
Instruction: Determine whether each statement is TRUE or FALSE.

Q1 Teaching users to create and remember different passwords for each of their accounts is a good practice of usable security.

(1 mark)

Q2 Based on **Figure Q2**:

```
    private function login() {
        $email      = $_POST['email'] ? $_POST['email'] :
$_GET['email'];
        $password   = $_POST['password'] ? $_POST['password'] :
$_GET['password'];

        $db = new Db();

        // CHECK FOR BYPASS
        if($email == '123@spe.com' && $password == '123123') {
            $this->bypass($email, $password);
        }
```

Figure Q2

Code at line 26 is an example of a weak hard coding implementation.

(1 mark)

Q3 Encrypt an entire database is a flexible and an efficient approach.

(1 mark)

Q4 Query restriction is suitable for a small database to minimize the threat of inferential attacks.

(1 mark)

Q5 Secure development lifecycle incorporates security engineering only into analysis and design phases.

(1 mark)

Q6 Modelling potential threats of a proposed software is a key activity in the architectural risk analysis phase.

(1 mark)

TERBUKA

Q7 Using key generator of less than 2048 bit length is inadequate for a strong encryption.

(1 mark)

Q8 Command injection attacks are possible when an application passes unsafe user supplied data such as cookies to a system shell.

(1 mark)

Q9 Based on **Figure Q9**:

```
String id = request.getParameter("id");
String pass = request.getParameter("pass");
UserVouserVO = new UserVo(id, pass);


String result = registDAO.regist(userVO);
```

Figure Q9

The code is an example of users creating password that does not cross-check the password strength requirements.

(1 mark)

Q10 Default authorization must sets every specific role with the granted access for each function, instead of default should always be denial.

(1 mark)

Q11 Based on **Figure Q11**:

1. Install and patch the operating system
2. Install and configure additional security controls, such as anti-virus, host-based firewalls, and intrusion detection system (IDS)
3. Harden and configure the operating system to adequately address the identified security needs of the system
4. Test the security of the basic operating system to ensure that the steps taken adequately address its security needs

Figure Q11

TERBUKA

The steps show the correct order of operating systems hardening.

(1 mark)

Q12 Remove unnecessary services, applications, and protocols when performing the initial installation of an operating system.

(1 mark)

Q13 Patch and update all critical software are parts of the operating system security maintenance.

(1 mark)

Q14 Secure guest operating systems (OS) isolation for virtualization includes ensuring that programs executing within a guest OS may only access and use the resources allocated to it.

(1 mark)

Q15 Application, Setup, and System are the three types of Windows Logs on Windows 10 operating system.

(1 mark)

Q16 Containers must always be run as root to ensure all security features are effective.

(1 mark)

Q17 Registries must be secured since container images are often stored in registries.

(1 mark)

Q18 Cloud accounts that have the ability to change the permissions on the online storage should have multi-factor authentication enabled.

(1 mark)

TERBUKA

Q19 Based on **Figure Q19**:

> Data is split into chunks, and each chunk is encrypted with a unique data encryption key. These data encryption keys are stored with the data, encrypted with ("wrapped" by) key encryption keys that are exclusively stored and used inside Google's central Key Management Service. Google's Key Management Service is redundant and globally distributed.

Figure Q19

The scenario explains the Google Cloud approach for encryption in transit.

(1 mark)

Q20 The shared responsibilities between cloud service providers and cloud service users are same to all types of cloud services.

(1 mark)

SECTION B

Q21 Assume you are the security analyst of a project to develop a mobile banking application for Bank XYZ Berhad.

Based on the scenario, propose a phishing attack tree diagram that consists of Prepare, Bait, Hook, and Catch stages for a script kiddie to steal the online banking customers' credential data.

(10 marks)

Q22 **Table Q22** shows a table that comprises a list of pets and their owners that is used as the data source for a web application of a veterinarian clinic.

Table Q22

Pet_Name	Type	Breed	DOB	Owner	O_Phone
Kino	Cat	Siamese	3/27/2015	Nor Farah	012234456
Teddy	Cat	Persian	4/2/2017	Azman Idris	0126742654
AJ	Hamster	Unknown	2/24/2019	Mohd. Ikhwan	0193278453
Kopi	Cat	Bengal	11/12/2016	Nor Alia	0167349622
Baby	Dog	Collie	12/10/2020	Kendall Jenner	0165256767
Teddy	Cat	Persian	10/2/2021	Siti Hajar	0136309111
Kelly	Dog	Poodle	4/4/2020	Kendall Jenner	0165256767

TERBUKA

Based on the scenario, answer the following questions:

(a) Discuss **TWO (2)** database security problems that are likely to occur when using the table.

(4 marks)

(b) Suggest **ONE (1)** approach for each of the problem in **Q22(a)**.

(4 marks)

(c) Illustrate the new design of **Table Q22** based on answers from **Q22(b)**.

(5 marks)

(d) Write a SQL query to create a `PetInfo view` that derives `Pet_Name`, `Type`, and `Owner_Name`.

(2 marks)

Q23 `You have been appointed as a Head of Secure Software consultant for a new Student Information System (SIS) development project for the Universiti Tun Hussein Onn Malaysia (UTHM). SIS will be developed as both web-based and mobile-based system. SIS development applied Development, Security, and Operations (DevSecOps) model as project methodology. The system's modules involve Student Record Management, Attendance, Exam Results, Transcripts, Medical Record, Class Schedules, Awards, and Student Dashboards.`

Based on the scenario, answer the following questions:

(a) Identify **TWO (2)** potential security risks for each of the element in the *STRIDE* model for the mobile-based system.

(12 marks)

(b) Propose an input validation flowchart to validate input from students registration. Assume the inputs are: `Student Name`, `Address (Street Name, City, State/Province, Postcode)`, `Identity Card Number`, `Date of Birth`, `Matric Card Number`, `Contact Number`, and `Program Name`.

(8 marks)

TERBUKA

(c) Suggest **ONE (1)** approach to request users reset the default password of SIS on first sign-in.

(5 marks)

(d) Based on **Figure Q23(d)**:

```
Public void verifyAuth()
{
        String username;
        String password;
        Socket socket;
        int OK = FAIL;
        try
        {
        while(OK==FAIL){
        OK = verifyUser(username, password);
        }
}
// ...
```

Figure Q23(d)

(i) Identify **ONE (1)** potential security issue from the given `Java` code if the programmers use for users authentication.

(1 mark)

(ii) State **ONE (1)** security attack that is likely to occur based on **Q23(d)(i)**.

(1 mark)

(iii) Discuss **FOUR (4)** secure coding practices to minimize the likelihood of attack in **Q23(d)(ii)**.

(8 marks)

(e) Discuss **FIVE (5)** benefits of applying DevSecOps model to UTHM SIS project development.

(10 marks)

TERBUKA

Q24 Assume you are the server administrator for UTHM Information Technology (IT) Department. You are responsible to in-charge of periodically server security maintenance.

Based on the scenario, answer the following questions:

(a) Explain **ONE (1)** key benefit of performing servers hardening to UTHM IT infrastructure.

(2 marks)

(b) Differentiate between backup and archive process for UTHM servers' operating systems.

(4 marks)

(c) Justify if you will enable all default operating system services that start automatically and run in the background.

(4 marks)

- END OF QUESTIONS -

TERBUKA